



Human-Centric Detection, Response & Workflows

Notes from Session 3 of 3, the final session in the CLC: 2026 Certified AI Email Security Specialist learning path: what happens to malicious and unwanted mail after it reaches the inbox, and how to close the loop between detection, investigation, and remediation without burning security team hours.

PRESENTER

Matt Cooke, Director, Cybersecurity Strategy

ON THIS PAGE

- 01 The mail that gets through anyway
- 02 What manual triage costs
- 03 How a post-delivery layer fits in
- 04 Handling suspicious mail
- 05 Investigation: native tools vs. one pane
- 06 Breaking the graymail cycle
- 07 From reported email to closed incident
- 08 Unified remediation
- 09 Closing summary

QUICK RECALL

CLEAR closes the loop: auto-resolve what the system already knows, route what it doesn't to lightweight triage, and feed the outcome back so the next report is faster to sort.

The mail that gets through anyway

No filter is perfect. Confirmed-malicious, merely suspicious, and simply unwanted mail all still land in front of users and security teams after delivery, and each needs a different response.

MALICIOUS EMAIL

Built to evade defenses, often with dynamic or time-delayed payloads that only activate after the message has already been scored clean.

END-USER REPORTED EMAILS

Abuse-mailbox submissions, partially identified campaigns, and plain mis-reports, a mixed pile that needs its own triage before it's useful.

UNWANTED EMAIL

Compliance violations and inappropriate content: low on threat, but still needs a policy response.

02 · THE COST

What manual triage costs

Post-delivery cleanup is a multi-stage relay, and every handoff adds dwell time while a bad message sits in an inbox.

A reported message typically opens with 5 to 30 minutes of notification triage, then 1 to 2 hours of manual investigation, threat and user enrichment, and alerts to the messaging team. From there, messaging admins spend another 1 to 2 days searching for and quarantining every copy of the message, and the security team closes it out with a further 1 to 2 days of metrics, control adjustments, and lessons learned.

One Fortune 100 insurer's numbers: 3,900 reporting users generated roughly 11,000 reported messages over six weeks, about 46 every working hour. At 190 minutes of combined handling time per malicious or suspicious report, the 5,100 malicious reports alone worked out to about 2,019 person-days of effort over that same six-week window; the remaining 5,900 non-malicious reports, at five minutes each, still cost roughly 61 person-days.

How a post-delivery layer fits in

A secure email gateway isn't the whole story: it filters inbound mail before delivery, but a second control point has to pick up after the message lands.

Inbound mail flows from the internet through the email security service, which decides whether to block, deliver, or deliver with a warning; a message can be decorated with a suspicion banner and simple actions rather than dropped outright. Clean mail reaches the mailbox, where the client reads and sends as normal, but a separate API connection into the mailbox itself gives the security layer visibility and control after delivery too, covering abuse-mailbox management and end-user triage and remediation on messages that already made it through.

Why flexibility matters: in one example set, suspicious classifications outnumbered confirmed-malicious ones roughly 5 to 1, the reason a rigid block-or-allow gateway isn't enough on its own. Suspicious mail needs a lighter-touch response: quarantine by confidence level, or deliver with a warning, rather than a full investigation every time.

Handling suspicious mail without over-investigating

Fewer investigations for suspicious mail starts with more granular controls and real-time coaching, not a bigger triage queue.

Suspicious mail can be quarantined by confidence level (all, medium, high, or malicious-only) instead of an all-or-nothing rule, so borderline messages don't automatically turn into investigations. When a message does reach the inbox with a warning, the banner spells out exactly why: a look-alike sending domain, a false sense of urgency, and a financial request get called out individually, and the user can report and delete it or release it themselves in one click, with links and attachments disabled in the preview either way.

Investigation workflows: native tools vs. one pane

Native Microsoft 365 tools can answer most of the same questions, just by stitching several tools together instead of opening one screen.

NATIVE MICROSOFT 365

Message trace in the Exchange admin center pulls delivery details, and Defender for Office 365's advanced hunting adds Kusto Query Language (KQL) queries for anything trace alone can't answer. Both expect an admin comfortable copying and pasting email attributes and writing hunting queries by hand.

THREAT PROTECTION WORKBENCH

Message analysis, sender analysis, and threat analysis sit on one screen, alongside a full delivery timeline and the exact rule that passed or blocked the message, so an analyst can read the whole story and remove the message from the mailbox or flag it as a false negative without leaving the page.

Breaking the graymail cycle

Not every unwanted message is a threat, and treating it like one wastes triage time that should go to real investigations.

A classic graymail loop starts with signing up for a newsletter for a shot at winning something, then losing interest (or the raffle) and deleting, unsubscribing, reporting as junk or phishing, or blocking the sender, only to subscribe to the next promotion and repeat the cycle.

SIMPLIFIED CONFIGURATION

Spam and graymail each get their own remediation policy, track only (log a security event, take no action) or move straight to the default junk folder, set once per category instead of per rule.

LEARNS FROM USER BEHAVIOR

Low-priority inboxes, untrusted-sender lists, and adaptive folders build themselves from how people treat repeat senders, so graymail self-sorts over time

instead of generating a fresh report every cycle.

07 · CLOSING THE LOOP

From reported email to closed incident

Native abuse-mailbox handling and an automated version solve the same problem at very different speeds.

NATIVE MICROSOFT 365

Admins review and resubmit reported emails one at a time and lean on Defender's Explorer for hunting. Workable, but entirely manual.

AUTOMATED ABUSE MAILBOX

A reported-email queue classifies, remediates, and triages automatically, tagging each item auto-remediated, admin-remediated, no action needed, or still needing action, so only genuinely ambiguous cases reach a person.

Closed Loop Email Analysis and Response (CLEAR): every employee-reported message is auto-resolved (sorted into malicious, spam, bulk, or low-risk) or flagged for review (suspicious, likely harmless, or unknown, then run through custom content rules). Either path ends in a closed incident needing no action or an open incident for manual triage, and both can trigger a quarantine, a delete, or a forced password change. User feedback on the outcome feeds straight back into the reported-message queue, which is what closes the loop.

08 · UNIFIED REMEDIATION

Unified remediation

Once something is confirmed bad, the last step is making sure other systems know about it too, without a person copying data between tools.

A direct API feeds Proofpoint data into SIEM and SOAR tooling generally, and purpose-built integrations extend that into Splunk through a no-code app, Okta, Sumo Logic, and Palo Alto Cortex XSOAR, so ingestion, and in XSOAR's case remediation too, can happen from inside the security team's own console instead of a separate portal.

PROOFPOINT API

SPLUNK

OKTA

SUMO LOGIC

PALO ALTO CORTEX XSOAR

09 · WRAP-UP

Closing summary

The pattern repeats at every layer: let the system act on its own where it can (auto-quarantine, auto-remediate, auto-classify) and save people for the genuinely ambiguous calls. Fewer investigations for suspicious mail, simpler investigation workflows, smarter spam and graymail handling, faster response to user-reported email, and unified remediation through SIEM and SOAR are five different levers on the same problem: shrinking the time between a bad email landing and someone dealing with it.

"Detection before delivery only solves half the problem. The other half is how fast the loop closes once something gets through anyway."

SESSION SYNTHESIS, BASED ON MATT COOKE'S CLOSING FRAMING

Final session in the AI Email Security Specialist path.